MITIGATING COMPROMISED K-12 GOOGLE WORKSPACE/MICROSOFT 365 FOR EDUCATION ACCOUNTS

Reasonable Belief of Account Compromise

- User report/help desk ticket
- Internal alert/dark web monitoring
- Notification/complaint from third party

When K-12 user accounts are compromised, it takes **more than a password reset** to ensure the ongoing security and privacy of your school system's data and IT systems. Developed by K-12 IT practitioners for K-12 practitioners, this checklist and accompanying guidance can help direct your response. For more, visit: https://www.k12six.org/essentials-series

Isolate

- Reset password immediately
- Revoke sessions
- Suspend account/ elevated privileges
- Preserve evidence

Investigate

- Review sign-in logs
- Scrutinize mailbox activity
- Inspect file activity/shares
- Check for unauthorized or suspicious apps/ APIs
- Check for unauthorized accounts/group additions

Remediate

- Quarantine sent malicious emails and reverse suspicious mailbox changes
- Remove/revoke unauthorized files/share, apps, APIs, and accounts
- Check status of any connected accounts
- Validate MFA
- Update alert triggers
- Scan for malware
- Continue to monitor for unusual activity

Communicate

- Alert and educate affected users
- Report to internal leadership
- Notify any potentially affected third parties
- Share IOCs with K12 SIX/other threat intel sharing groups
- If directed, notify law enforcement

Reevalaute

- Review and enhance policies, incident response plans, IT practices, and awareness training
- Consider whether additional security controls are warranted

ACT WITH URGENCY ***DOCUMENT YOUR WORK*** ***PRESERVE EVIDENCE***

MITIGATING COMPROMISED K-12 GOOGLE WORKSPACE FOR EDUCATION ACCOUNTS: GUIDANCE *v1.0 (May 2024)*

IMPORTANT:

Act with Urgency: Time is of the essence to minimize the impact of a compromised account.

Document Your Work: Thoroughly document every step and evidence found for analysis and possible legal action.

Preserve Evidence: Avoid unnecessary changes that might taint evidence, especially if legal action seems likely. Consult experts if needed.

Be aware some steps may change based on your license or configuration.

STEP 1: ISOLATE

- **Immediately Reset Password:** Enforce a password change for the compromised account. Ensure a strong, complex, and unique password.
- **Revoke Sessions:** One option is to revoke sign-in cookies: go to the User, then to the Security Tab. Under that tab is the Sign-In Cookies which will revoke and reset all their "sessions." Another method is in the Google Admin Console (admin.google.com) under "Device> Mobile & endpoints > Devices." Search for user, highlight device and click block.[1]

[1] Revoking sessions is different from revoking access. Revoking sessions signs the user out, while revoking access removes the user's authorization to access resources. Both actions may be necessary depending on the situation. In the Google Admin console:

- Navigate to Security -> Settings -> Session control
- Under "Web sessions", you'll see options to:
    - "End other web sessions immediately:" Force logs out the user on all devices except the one you're currently using.
    - "End all web sessions": Logs out the user across all devices.

To revoke access to a device, in the Google Admin console:

- Go to the Admin console -> Devices
- Select the category of devices: Chrome, Mobile, or Others.
- Locate the compromised device and take appropriate actions:
    - Device Wipe: Erase all user data from it.

- **Suspend Account (if warranted):** If you cannot quickly contain the spread, you may need to temporarily:
    - Suspend the user
    - Isolate the device: Suspend the computer's access via Defender/deployed EDR tool. For BYOD, consider MAC address block.
- **Adjust Admin Roles (if applicable):** Temporarily or permanently remove administrative privileges from the compromised account until the situation is completely resolved. Snapshot roles/groups before making changes.
- **Preserve Evidence:** If you don't force retention on all documents and emails, consider activating a legal hold on compromised accounts, especially if legal or extended forensic needs are likely. Set indefinite retention. Be prepared to redact PII in public disclosures. In Google Workspace:
    - Go to Vault > Matters. Create matter and enter user criteria.
    - Click the hold tab and set for each service.
    - Enter start date and leave end date open.

STEP 2: INVESTIGATE

- **Review Sign-in Logs:** In Google Workspace: Go to Reports -> Audit Log -> Login (in the Admin console); with Google Plus consider using Investigation tool
- **Scrutinize Mailbox Activity:** Check relevant audit logs for:
    - Mail forwarding changes
    - New/changed inbox filters/rules
    - Email deletion
    - Signature updates
    - New delegate access
    - New RSS feeds
    - Sent mail (external, internal)

    - Block Device: Prevent further sign-ins.

Similar actions can also be taken by individual users. To revoke session access:

- Have the user access their Google account
- Go to Security -> Your devices.
- Under "Where you're signed in", select Manage devices.
- For any unfamiliar or suspicious devices, click on the device and choose "Sign out".

To revoke device access:

- Have the user go to their Google Account
- Under Security -> Your devices -> Manage devices, identify the device.
- Click on the device and select "Sign Out".

- **Inspect File Activity/Shares:** Check drive activity logs, shared drives/groups for unusual file access/sharing, deletions, uploads/downloads, and search terms.
- **Check for Unauthorized or Suspicious Apps and APIs:** Go to Security -> API Controls -> Third-party OAuth Access, check app registrations & granted permissions.
- **Check for Unauthorized Accounts/Group Additions** (local and/or domain/enterprise), shares, etc.
- **Invoke Cybersecurity Incident Response (IR) Plan** if circumstances dictate.

Step 3: Remediate

- **Quarantine Sent Malicious Emails** to all users of a similar nature. Check for both similar sender address emails and similar subject emails. Check both malicious emails sent to your tenant, and malicious emails sent by the compromised user.
- **Reverse Suspicious Mailbox Changes**, such as mail forwarding/filter/rule changes, deleted emails, signature updates, delegate access, RSS feed changes, etc.
- **Remove/Revoke Access to Any Suspicious Apps, APIs, and Shares/Files,** including permissions changes and app passwords.
- **Remove Any Unauthorized New Accounts** (local and/or domain/enterprise).
- **Check Connected Accounts:** If the compromised account credentials were used on other services connected to it, take similar actions (password resets, permissions reviews) on those services.
- **Validate Multi-Factor Authentication (MFA):** If not already in place, check for new MFA method for the compromised user in your tenant. Reset backup/recovery codes.
- **Update Alert Triggers**, as appropriate, based on lessons learned.
- **Scan for Malware:** Scan devices recently used by the compromised user (user may be at home/personal device, including a mobile device or tablet) with up-to-date antivirus/anti-malware software. Assume device may have a password stealer and don't login with global admin accounts.
- **Continue to Monitor for Unusual Activity:** Keep a close eye on the compromised account (and the organization) for signs of further compromise.

Step 4: Communicate

- **Alert and Educate Affected Users**, including patient zero: If there was communication from the compromised account, notify other users about the potential exposure/danger of password re-use. Provide affected users with training on phishing, password security, and recognizing/reporting suspicious activity.

- **Report to Internal Leadership** following internal policies, including compliance with any regulatory reporting requirements based on the sensitivity of data involved.
- **Notify any Potentially Affected Third Parties,** including cloud providers (e.g., Google), other school districts (or other organizations) involved/targeted.
- **Share Indicators of Compromise (IOCs) with K12 SIX** (via threat intel sharing portal or by emailing soc@k12six.org), other threat intel sharing groups, and peer school systems.
- **If Directed, Notify Law Enforcement** and other agencies as required/appropriate.

STEP 5: REEVALUATE

- **Review and Enhance Policies and Procedures**, including incident response plans, IT practices, and user awareness training.
- **Consider Additional Security Measures:** Assess the value of advanced threat protection, phishing simulations, and other security tools based on your risk profile and lessons learned.

MITIGATING COMPROMISED K-12 MICROSOFT FOR EDUCATION ACCOUNTS: GUIDANCE *v1.0 (May 2024)*

IMPORTANT:

Act with Urgency: Time is of the essence to minimize the impact of a compromised account.

Document Your Work: Thoroughly document every step and evidence found for analysis and possible legal action.

Preserve Evidence: Avoid unnecessary changes that might taint evidence, especially if legal action seems likely. Consult experts if needed.

Be aware some steps may change based on your license or configuration.

STEP 1: ISOLATE

- **Immediately Reset Password:** Enforce a password change for the compromised account. Ensure a strong, complex, and unique password.
- **Revoke Sessions:** Sign the user out of all sessions in the Microsoft 365 Admin Center.[2]

[2] Revoking sessions is different from revoking access. Revoking sessions signs the user out, while revoking access removes the user's authorization to access resources. Both actions may be necessary depending on the situation. To revoke sessions in Microsoft 365:

- Go to the Microsoft 365 admin center
- Go to Users>Active Users and locate the user whose sessions you want to revoke
- In the user's profile, locate the "sign out of all sessions" link.

Once clicked you will get this message "We have initiated a sign-out for the user. It may take some time to sign out the user from all sessions on all devices."

All sessions for that user have been expired and are no longer valid. This will sign the user out of all their active Microsoft 365 sessions, forcing them to sign in again. The process may take up to 15 minutes to complete.

Alternatively, you can also go to the Entra Admin Center:

- On the left hand side go to Identity> All Users and search for the compromised user
- Click on the user to display the profile panel and under the overview section you will see "Revoke Sessions" on the top of the panel.

- **Suspend Account (if warranted):** If you cannot quickly contain the spread, you may need to temporarily:
    - Block sign-ins for the account.
    - Isolate the device: Suspend the computer's access via Defender/deployed EDR tool. For BYOD, consider MAC address block.
- **Adjust Admin Roles (if applicable):** Temporarily or permanently remove administrative privileges from the compromised account until the situation is completely resolved. Snapshot roles/groups before making changes.
- **Preserve Evidence:** If you don't force retention on all documents and emails, consider activating a legal hold on compromised accounts, especially if legal or extended forensic needs are likely. Set indefinite retention. Be prepared to redact PII in public disclosures.

STEP 2: INVESTIGATE

- **Review Sign-in Logs:** Check Azure Active Directory sign-in logs for unusual locations, unknown devices, unexpected timestamps, client used.
- **Scrutinize Mailbox Activity:** Check relevant audit logs for:
    - Mail forwarding changes
    - New/changed inbox filters/rules
    - Email deletion
    - Signature updates
    - New delegate access
    - New RSS feeds
    - Sent mail (external, internal)
- **Inspect File Activity/Shares:** Check OneDrive/SharePoint audit logs for unusual file access/sharing, deletions, uploads/downloads, and search terms.
- **Check for Unauthorized or Suspicious Apps and APIs:** In Azure AD, check app registrations & granted permissions.
- **Check for Unauthorized Accounts/Group Additions** (local and/or domain/enterprise), shares, etc.
- **Invoke Cybersecurity Incident Response (IR) Plan** if circumstances dictate.

- It will display the following question "Do you want to revoke all sessions for the user? This will revoke all sessions for the user "CompromisedUser", requiring the user to re-sign in from all devices.
- Click Yes

A banner will appear saying "Successfully revoked sign-in sessions"

Step 3: Remediate

- **Quarantine Sent Malicious Emails** to all users of a similar nature. Check for both similar sender address emails and similar subject emails. Check both malicious emails sent to your tenant, and malicious emails sent by the compromised user.
- **Reverse Suspicious Mailbox Changes**, such as mail forwarding/filter/rule changes, deleted emails, signature updates, delegate access, RSS feed changes, etc.
- **Remove/Revoke Access to Any Suspicious Apps, APIs, and Shares/Files,** including permissions changes and app passwords.
- **Remove Any Unauthorized New Accounts** (local and/or domain/enterprise).
- **Check Connected Accounts:** If the compromised account credentials were used on other services connected to it, take similar actions (password resets, permissions reviews) on those services.
- **Validate Multi-Factor Authentication (MFA):** If not already in place, check for new MFA method for the compromised user in your tenant. Reset backup/recovery codes.
- **Update Alert Triggers**, as appropriate, based on lessons learned.
- **Scan for Malware:** Scan devices recently used by the compromised user (user may be at home/personal device, including a mobile device or tablet) with up-to-date antivirus/anti-malware software. Assume device may have a password stealer and don't login with global admin accounts.
- **Continue to Monitor for Unusual Activity:** Keep a close eye on the compromised account (and the organization) for signs of further compromise.

Step 4: Communicate

- **Alert and Educate Affected Users**, including patient zero: If there was communication from the compromised account, notify other users about the potential exposure/danger of password re-use. Provide affected users with training on phishing, password security, and recognizing/reporting suspicious activity.
- **Report to Internal Leadership** following internal policies, including compliance with any regulatory reporting requirements based on the sensitivity of data involved.
- **Notify any Potentially Affected Third Parties,** including cloud providers (e.g., Microsoft), other school districts (or other organizations) involved/targeted.
- **Share Indicators of Compromise (IOCs) with K12 SIX** (via threat intel sharing portal or by emailing soc@k12six.org), other threat intel sharing groups, and peer school systems.

- **If Directed, Notify Law Enforcement**

STEP 5: REEVALUATE

- **Review and Enhance Policies and Procedures**, including incident response plans, IT practices, and user awareness training.
- **Consider Additional Security Measures:** Assess the value of advanced threat protection, phishing simulations, and other security tools based on your risk profile and lessons learned.

Disclaimer: K12 SIX makes no representations or warranties with respect to the accuracy or completeness of the content herein and specifically disclaims any implied warranties of merchantability or fitness for a particular purpose. The advice contained herein may not be suitable for your situation. K12 SIX shall not be liable for any loss or damages, including but not limited to special, incidental, consequential, or other damages.